

# StockRoom

A small inventory app, shipped the DevSecOps way

DevOps Capstone · github.com/u7k4rs6/Capstone

# What I built

## Track stock

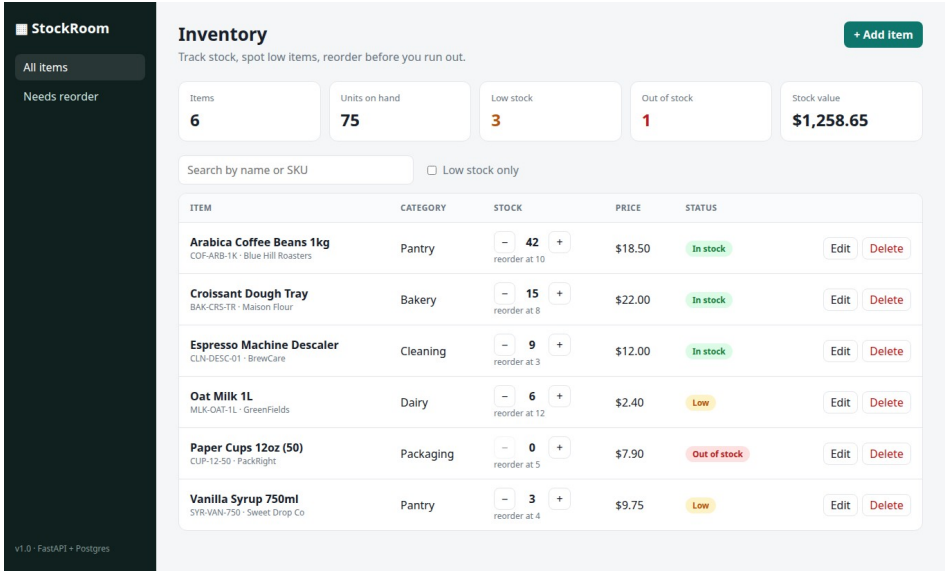
Add items, bump quantities up or down, edit or delete

## Spot low items

Anything at or under its reorder level gets flagged

## Ship it properly

Every push is tested, scanned and rolled out by ArgoCD




React + FastAPI + Postgres. 10 API routes, 12 tests.

# Tech stack

### App
React 19, FastAPI, Postgres 17, Alembic

### Testing
pytest on SQLite, ruff

### Containers
Docker, Compose, non-root

### CI/CD
GitHub Actions, GHCR

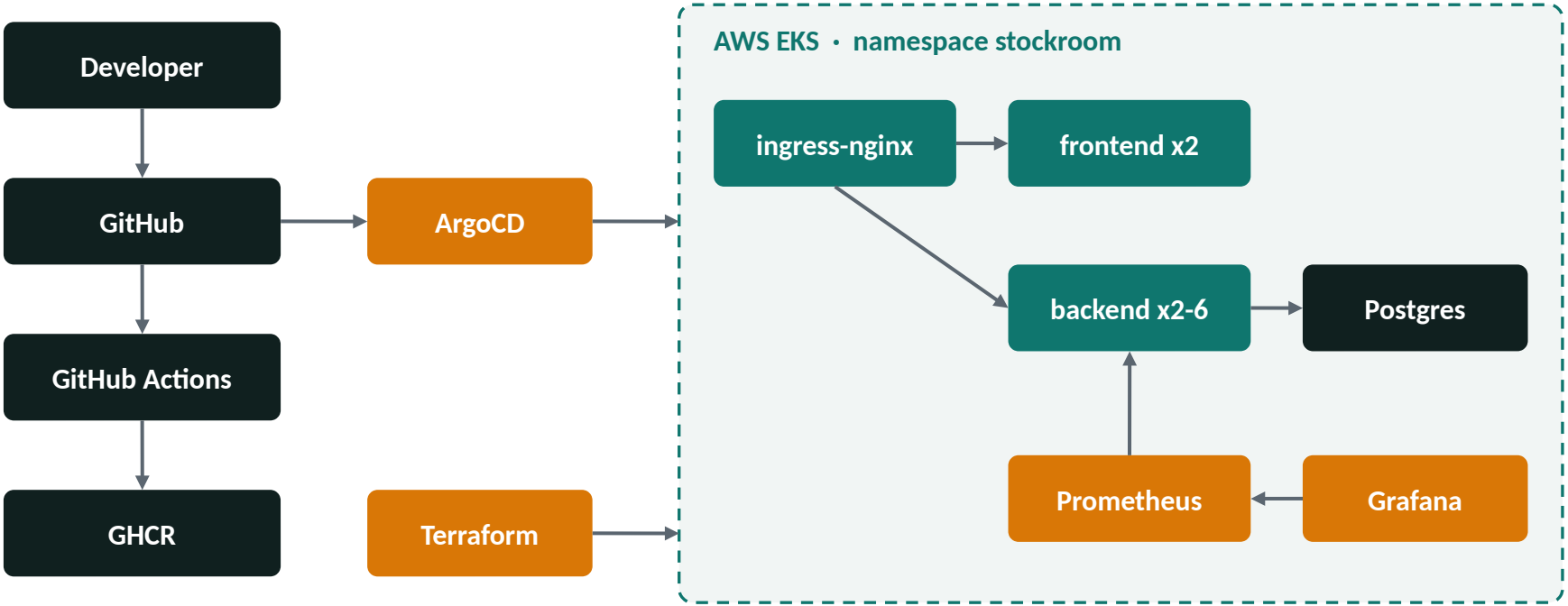
### Security
Trivy, fail on HIGH/CRITICAL

### Infra
Terraform, AWS VPC + EKS

### Deploy
Helm, ArgoCD, HPA, ingress

### Observability
Prometheus, Grafana

# Architecture




/ goes to frontend, /api goes to backend. Prometheus scrapes /metrics.

# CI/CD pipeline

**1**

### Test

ruff, pytest -v, npm build

**2**

### Build

both images, tagged with commit SHA

**3**

### Scan

Trivy, fails on HIGH or CRITICAL

**4**

### Push

ghcr.io/ u7k4rs6/ stockroom-*

**5**

### Bump

CI commits new tag to values.yaml

**6**

### Sync

ArgoCD rolls the cluster forward

Runs on every push to main. PRs get test + build + scan, but nothing is pushed or deployed.

**Why SHA tags:** any pod in the cluster traces back to the exact commit. No guessing what "latest" means.

# Security gate with Trivy

**4 → 0**

HIGH CVEs in the backend image, first scan vs now

Frontend: clean from day one

## What it scans

OS packages (Debian, Alpine) and Python wheels inside both final images.

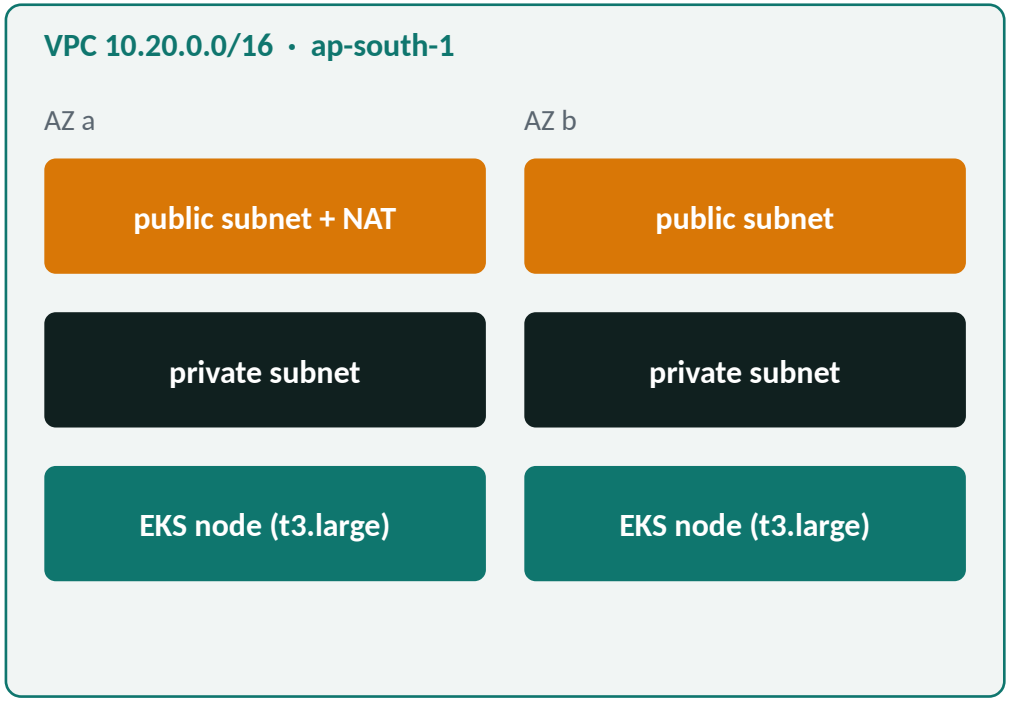
## What it found

setuptools CVE-2025-47273, 2 urllib3 CVEs, 1 msgpack. All inside pip's vendored copies.

## The fix

pip is build-time only, so the Dockerfile uninstalls it. Scan went clean.

# Infrastructure with Terraform




- 2 public + 2 private subnets over 2 AZs
- EKS 1.35, managed node group 2 to 4
- Add-ons: VPC CNI, CoreDNS, kube-proxy, EBS CSI
- Subnets tagged so load balancers land in public ones
- No keys in git. tfvars.example only

**init → plan → apply → destroy**

# Kubernetes, Helm and ArgoCD

### Deployments

frontend x2, backend x2 with HPA up to 6 at 60% CPU

### Postgres

StatefulSet + PVC, backend waits on it with an init container

### Networking

ClusterIP services, ingress splits / and /api

### Hardening

non-root, no privilege escalation, all caps dropped



### GitOps loop

1. Push to main
2. CI writes new SHA into values.yaml
3. ArgoCD sees the commit
4. Auto sync, prune, self-heal

# Observability




## /metrics

request count and latency per endpoint, plus a custom stock movement counter

## Prometheus

ServiceMonitor picks up every backend pod, all UP

## Grafana

dashboard ships with the chart: traffic, p95, 5xx rate, stock moves

# Key learnings

### Replicas race on first boot

Two pods ran migrations at once and crashed. Fixed with an init container and a Postgres advisory lock.

### CVEs hide in your tooling

Every Trivy hit was in pip, not the app. Shipping less fixes more than patching.

### Red targets aren't always bugs

Managed control planes hide their metrics. Turned those scrapes off so real failures stand out.

### Pin what you run

Actions pinned by SHA, images tagged by SHA. Tags move, hashes don't.



# Live demo

Code · CI run · Terraform · ArgoCD · kubectl · Prometheus · Grafana

github.com/u7k4rs6/Capstone